



Faculdade de Informática e Administração Paulista

Engenharia de Software – 3ESPS

Lucas Reis Diniz - RM552838

Thiago Araújo Vieira - RM553477

Vitor de Moura Nascimento - RM553806

EcoSaúde

Do espaço para a saúde das comunidades.

Da Terra para o futuro da humanidade.

SÃO PAULO

2026

RESUMO

Este trabalho apresenta a integração de práticas de DevSecOps ao EcoSaúde, solução desenvolvida para a Global Solution FIAP 2026 com o objetivo de utilizar dados espaciais, inteligência artificial e computação de borda para apoiar ações relacionadas à saúde pública, saneamento básico e sustentabilidade. A proposta busca transformar dados provenientes de satélites, sensores ambientais e APIs climáticas em informações estratégicas capazes de auxiliar gestores públicos e comunidades na identificação de riscos socioambientais.

Diferentemente de aplicações tradicionais, o EcoSaúde depende da confiabilidade de dados ambientais e geoespaciais para gerar previsões e indicadores que podem influenciar decisões relacionadas ao controle de doenças, qualidade da água, qualidade do ar e gestão de recursos públicos. Nesse contexto, falhas de segurança podem comprometer não apenas a infraestrutura tecnológica, mas também a credibilidade das análises produzidas pela plataforma.

Para mitigar esses riscos, foram incorporadas práticas DevSecOps ao ciclo de desenvolvimento da solução. O projeto inclui mecanismos de análise estática de código, auditoria de dependências, detecção de segredos expostos, análise de vulnerabilidades em contêineres e aplicação de princípios de mínimo privilégio em ambientes orquestrados. Dessa forma, a segurança passa a fazer parte do processo de desenvolvimento desde as primeiras etapas do pipeline.

CONTEXTUALIZAÇÃO DA SEGURANÇA NO ECOSAÚDE

O EcoSaúde é uma plataforma de inteligência socioambiental projetada para consolidar informações provenientes de diferentes fontes de dados, incluindo satélites, APIs meteorológicas, bases ambientais e serviços geoespaciais. O objetivo é identificar regiões vulneráveis e gerar previsões relacionadas à disseminação de doenças, qualidade ambiental, saneamento básico e eventos climáticos que possam impactar diretamente a população.

A arquitetura da solução é composta por microsserviços especializados em forecast ambiental, monitoramento da qualidade da água, análise da qualidade do ar, acompanhamento de indicadores sanitários e processamento geoespacial. Esses serviços são empacotados em contêineres e preparados para execução em ambientes modernos de orquestração, como Kubernetes e K3s.

Por depender de integrações externas e de um grande volume de dados, a plataforma possui uma superfície de ataque considerável. A exposição de credenciais, a utilização de bibliotecas vulneráveis ou a execução inadequada de contêineres podem comprometer a integridade dos dados processados e gerar previsões incorretas. Considerando que essas informações podem apoiar decisões relacionadas à saúde pública e ao saneamento, a segurança foi tratada como um requisito fundamental da solução.

Nesse cenário, a adoção de práticas DevSecOps permite incorporar mecanismos de proteção diretamente ao pipeline de desenvolvimento, garantindo que falhas sejam identificadas antes da implantação da aplicação em produção.

FUNDAMENTAÇÃO DO RISCO

A relevância da segurança no EcoSaúde é reforçada pelo impacto social das informações geradas pela plataforma. Dados da Organização Mundial da Saúde apontam que, somente em 2024, foram registrados mais de 14 milhões de casos de dengue no mundo, demonstrando a importância de sistemas capazes de antecipar cenários críticos e apoiar ações preventivas.

Ao mesmo tempo, relatórios da WHO/UNICEF indicam que bilhões de pessoas ainda enfrentam dificuldades relacionadas ao acesso seguro à água potável e ao saneamento básico. Essas condições contribuem diretamente para o surgimento e disseminação de doenças, tornando essencial a existência de ferramentas que auxiliem o monitoramento ambiental e a tomada de decisão baseada em dados.

No contexto do EcoSaúde, a integridade das informações processadas é tão importante quanto a disponibilidade da plataforma. Dados adulterados, vulnerabilidades em componentes críticos ou falhas na cadeia de desenvolvimento podem gerar indicadores incorretos e comprometer ações preventivas. Por esse motivo, a segurança foi incorporada como parte integrante da governança tecnológica da solução.

MAPEAMENTO DE RISCOS NO PIPELINE

Risco	Cenário no EcoSaúde	Impacto	Controle
Vazamento de segredos	Chaves de APIs satelitais, climáticas, mapas e banco são incluídas no código ou em arquivos .env.	Acesso indevido a serviços externos, custos indevidos e exposição de dados.	GitHub Secrets, Gitleaks e bloqueio de pipeline.
Dependências vulneráveis	Bibliotecas Python com CVEs conhecidas são usadas pelos microsserviços.	Exploração da API e comprometimento de dados usados no forecast.	pip-audit e Dependabot.
Imagem Docker insegura	Imagem desatualizada, excesso de pacotes ou execução como root.	Container comprometido e risco de movimentação lateral.	Trivy, Dockerfile seguro e usuário não-root.
Permissões excessivas	ServiceAccount com privilégios amplos no cluster.	Escalada de privilégios em Kubernetes.	RBAC e princípio do menor privilégio.
Manipulação de telemetria	Pacotes ambientais chegam sem validação de origem ou integridade.	Forecast incorreto e decisão pública equivocada.	Logs auditáveis, autenticação e validação de integridade.

CONTROLES DE SEGURANÇA IMPLEMENTADOS

A estratégia de segurança adotada no EcoSaúde segue os princípios do DevSecOps, incorporando verificações automatizadas ao pipeline de integração contínua.

A gestão de segredos é realizada por meio do GitHub Secrets, impedindo que credenciais sensíveis sejam armazenadas diretamente no código-fonte. Complementando essa proteção, o Gitleaks executa verificações automáticas para identificar possíveis vazamentos de tokens, senhas ou chaves de acesso.

Para análise de código, foi utilizado o Bandit, ferramenta responsável por executar verificações SAST (Static Application Security Testing) em aplicações Python. Essa abordagem permite identificar padrões inseguros antes que sejam implantados em ambientes produtivos.

A auditoria de dependências é realizada através do pip-audit, que verifica bibliotecas utilizadas pelos microsserviços e identifica vulnerabilidades conhecidas registradas em bancos públicos de CVEs.

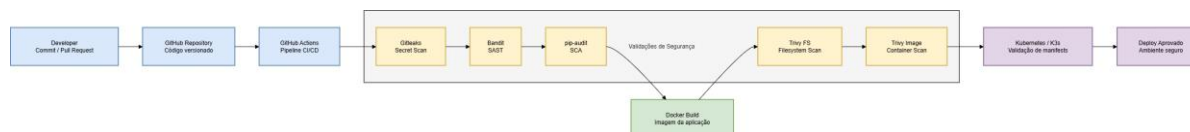
No contexto de contêineres, o Trivy foi adotado para análise de vulnerabilidades tanto no sistema de arquivos quanto nas imagens Docker geradas pelo pipeline. Além disso, os contêineres são executados com usuário não-root, sistema de arquivos somente leitura e restrições adicionais de segurança.

Por fim, a camada de infraestrutura utiliza RBAC e Security Context para limitar permissões e aplicar o princípio do menor privilégio nos ambientes Kubernetes e K3s.

ARQUITETURA DEVSECOPS DO PIPELINE

O pipeline implementado foi projetado para executar verificações de segurança de forma automática sempre que alterações forem enviadas ao repositório.

Anexo 01 – Pipeline DevSecOps do EcoSaúde



O fluxo inicia com o envio de código ao repositório GitHub. Em seguida, o GitHub Actions executa uma série de validações automatizadas. O Gitleaks verifica a existência de segredos expostos, o Bandit realiza análise estática de código e o pip-audit valida as dependências utilizadas pela aplicação.

Após essas verificações, a imagem Docker é construída e submetida ao Trivy, responsável por identificar vulnerabilidades em pacotes e componentes do sistema operacional. Somente após a aprovação dessas etapas o deploy é considerado apto para execução.

Essa abordagem reduz significativamente o risco de falhas chegarem ao ambiente produtivo.

IMPLEMENTAÇÃO PRÁTICA E EVIDÊNCIAS

A implementação foi realizada em um repositório GitHub funcional, contendo serviços FastAPI, arquivos Docker, manifestos Kubernetes e um pipeline DevSecOps baseado em GitHub Actions.

```
name: EcoSaude DevSecOps Pipeline
on: [push, pull_request]
jobs:
  security:
    runs-on: ubuntu-latest
    steps:
      - uses: actions/checkout@v4
      - uses: gitleaks/gitleaks-action@v2
      - run: pip install -r requirements.txt bandit pip-audit
      - run: bandit -r services -ll
      - run: pip-audit -r requirements.txt
      - run: docker build -t ecosauade-api:ci .
      - uses: aquasecurity/trivy-action@master
```

Durante o desenvolvimento foram identificadas vulnerabilidades reais por meio do pip-audit, incluindo dependências com versões suscetíveis a CVEs conhecidas. Também foram observados conflitos entre bibliotecas do ecossistema FastAPI e Starlette, exigindo ajustes nas versões utilizadas para garantir compatibilidade e segurança.



Além disso, análises realizadas com o Trivy demonstraram a importância da validação contínua das imagens Docker utilizadas pela aplicação.

As evidências coletadas durante essas validações encontram-se disponíveis no repositório na pasta:

docs/evidencias/

Os registros incluem capturas de tela dos scans executados, vulnerabilidades encontradas, conflitos de dependências identificados e as respectivas ações corretivas adotadas.

CONEXÃO COM OS OBJETIVOS DE DESENVOLVIMENTO SUSTENTÁVEL

A proposta do EcoSaúde está diretamente alinhada aos Objetivos de Desenvolvimento Sustentável definidos pela Organização das Nações Unidas.

O ODS 3 é contemplado por meio do apoio à prevenção de doenças e melhoria da saúde pública. O ODS 6 está relacionado ao monitoramento da qualidade da água e ao saneamento básico. O ODS 9 é atendido pela construção de uma infraestrutura tecnológica moderna, segura e resiliente. Por fim, o ODS 11 é contemplado pela contribuição para cidades mais inteligentes e sustentáveis.

CONCLUSÃO

A integração das práticas DevSecOps ao EcoSaúde demonstra que segurança não deve ser tratada como uma etapa isolada do desenvolvimento, mas como um componente essencial de toda a arquitetura da solução. Em projetos que utilizam dados espaciais, inteligência artificial e informações ambientais para apoiar decisões públicas, a confiabilidade dos dados torna-se tão importante quanto a disponibilidade dos sistemas.

Os controles implementados permitiram automatizar verificações de segurança, reduzir riscos associados a vulnerabilidades conhecidas e fortalecer a proteção de credenciais, contêineres e componentes de infraestrutura. Além dos benefícios técnicos, essas medidas contribuem para aumentar a confiança nos indicadores produzidos pela plataforma.

Dessa forma, o DevSecOps atua como um elemento estratégico para garantir que o EcoSaúde continue fornecendo informações confiáveis, seguras e relevantes para a sociedade.